Security & Privacy Disclosure, Final Report

About You / AY Outlet Android (de.aboutyou.outlet.app)

A hardcoded Firebase API key and database URL ship alongside three US third-party SDKs that initialize before any consent screen on a fashion app processing clothing sizes, purchase history and style preferences, and twice, across three follow-ups and 109 days, the one response received redirected RFI-IRFOS to a private HackerOne bug-bounty program instead of answering any of three technical questions, a redirect RFI-IRFOS explicitly rejected as inconsistent with a disclosure already public on its own permanent ledger

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, TWO REPLIES RECEIVED, BOTH A PLATFORM REDIRECT, THREE QUESTIONS NEVER ANSWERED

Target	About You GmbH & Co. KG (Otto Group), Hamburg
Package	de.aboutyou.outlet.app
Platform Audited	Android, static analysis of the production APK
Initial Disclosure (R1)	2026-06-30, to datenschutz@aboutyou.de (bounced) and security@aboutyou.de (delivered), CC presse@aboutyou.de, Austrian Datenschutzbehoerde, EDPS
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	4 (1 Critical, 2 High, 1 Medium)
Correspondence	7 messages sent by RFI-IRFOS over 109 days (2026-06-30 to 2026-09-12), 2 replies received (both 2026-08-27, from security@aboutyou.com), both redirecting to a private HackerOne bug-bounty program, none of the three technical questions answered
Authorities Notified	Austrian Datenschutzbehoerde (dsb@dsb.gv.at) · European Data Protection Supervisor (EDPS, edps@edps.europa.eu)

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6

4.1 C1: Hardcoded Firebase API key and production database URL in the production binary . . . 6

4.2 H1: Adjust and Facebook SDK initialize before consent, transferring fashion purchase-conversion data to Meta and Adjust in the US . . . 6

4.3 H2: Datadog RUM ContentProvider captures session analytics before consent, transferred to US infrastructure . . . 7

4.4 H3: Firebase initializes before consent, alongside a Braze CRM key present in app resources . . . 7

5 Impact Analysis 8

6 The Complete Chain: Seven Messages, 109 Days, Two Replies, Zero Answers 8

7 Data Protection – Article by Article 9

8 Regulatory & Legal Landscape 9

9 Indicators of Compromise 9

10 Disclosure Timeline & Outcome 10

11 Residual Risk & Recommendations 10

Executive Summary

About You / AY Outlet is the Android fashion-retail app of About You GmbH & Co. KG (Otto Group, Hamburg, approximately EUR 2.1 billion revenue, 11 million-plus active customers). A static analysis of the production APK found four findings, one CRITICAL, two HIGH and one MEDIUM, all concerning data processed in the course of ordinary fashion-shopping use: clothing sizes, purchase history and style preferences.

The app ships a hardcoded Firebase API key and production database URL directly in the binary (C1, both withheld from this public report; full values were disclosed privately to About You in the original R1 letter). Three separate US third-party SDKs initialize before any consent screen can render: Adjust and the Facebook SDK for marketing attribution and conversion tracking (H1), Datadog RUM for session analytics (H2), and Firebase together with a possible Braze CRM integration (H3). Each of these pre-consent initializations transfers data to US infrastructure with no Art. 44-49 transfer mechanism identified in the app's available privacy information.

RFI-IRFOS disclosed these findings on 30 June 2026 to datenschutz@aboutyou.de and security@aboutyou.de, with presse@aboutyou.de, the Austrian Datenschutzbehoerde, and the EDPS in CC, stating an embargo of 28 September 2026. The datenschutz@aboutyou.de address bounced immediately; security@aboutyou.de received the message. Two follow-ups (17 July, 15 August 2026) restated the three findings and three specific yes/no questions, drawing no reply for 58 days.

On 27 August 2026, security@aboutyou.com replied for the first time, inviting RFI-IRFOS to open a HackerOne account and resubmit the findings through About You's private bug-bounty program. RFI-IRFOS rejected this redirect the same day, pointing out that the findings had already been sitting in About You's own inbox for 58 days and were already public on RFI-IRFOS's permanent disclosure ledger, so moving them into a private, unpublished bounty channel would not add any information and was inconsistent with the coordinated-disclosure model this correspondence operates under. A second reply the same day repeated the HackerOne invitation without engaging with this objection or any of the three questions. A further follow-up was sent on 28 August 2026, and a final one on 12 September 2026 naming the redirect explicitly as rejected. No further reply arrived. The embargo of 28 September 2026 has now passed, 19 days overdue, with all three technical questions still unanswered on the day this report publishes.

ID	Severity	Title
C1	CRITICAL	Hardcoded Firebase API key and production database URL in the production binary
H1	HIGH	Adjust and Facebook SDK initialize before consent, transferring fashion purchase-conversion data to Meta and Adjust in the US
H2	HIGH	Datadog RUM ContentProvider captures session analytics before consent, transferred to US infrastructure
H3	MEDIUM	Firebase initializes before consent, alongside a Braze CRM key present in app resources

Subject & Operator Context

About You GmbH & Co. KG operates as part of the Otto Group, headquartered in Hamburg, Germany. RFI-IRFOS's original disclosure was addressed to datenschutz@aboutyou.de and security@aboutyou.de, with the Austrian Datenschutzbehoerde and the EDPS in CC. The datenschutz@aboutyou.de address returned an immediate delivery failure and remained unreachable for the rest of the correspondence; security@aboutyou.de received every message.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 30 June 2026 to datenschutz@aboutyou.de (bounced) and security@aboutyou.de (delivered), CC presse@aboutyou.de, the Austrian Datenschutzbehoerde and the EDPS, stating an embargo of 28 September 2026 and asking three specific yes/no questions: whether Adjust and the Facebook SDK had been moved behind a consent gate, whether an Art. 44-49 transfer mechanism existed for the Datadog RUM transfer to the US, and whether the dead datenschutz@aboutyou.de address would be repaired or security@aboutyou.de was the permanently correct channel. Follow-ups on 17 July and 15 August 2026 restated all three findings and all three questions, drawing no reply across 58 days.

On 27 August 2026, security@aboutyou.com replied, inviting RFI-IRFOS to provide a HackerOne username so the findings could be processed through About You's private bug-bounty program. RFI-IRFOS replied the same day, rejecting the redirect: the findings had already been in About You's inbox for 58 days across three prior messages, were already public on RFI-IRFOS's permanent disclosure ledger since 30 June 2026, and a private bounty channel is structurally built to keep a report unpublished, which is not the model this disclosure operates under. RFI-IRFOS named this explicitly as Pattern P-01 (The Webform Shuffle / VDP Redirect) of its own published Corporate Response Pattern Atlas, and restated all three questions in English. A second reply from security@aboutyou.com, also on 27 August 2026, cited About You's public security.txt and repeated the HackerOne invitation, again without addressing the objection or any of the three questions. RFI-IRFOS sent a further follow-up on 28 August 2026 and a final message on 12 September 2026, explicitly naming the redirect as rejected and the three questions as still unanswered after 74 days. No further reply arrived. The embargo of 28 September 2026 has now passed, 19 days overdue.

Findings

C1: Hardcoded Firebase API key and production database URL in the production binary

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 9.1 — reachable by anyone who decompiles an app used by 11 million-plus customers

```
google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to About You in R1]
firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to About You
    in R1]
Reachable by: any party decompiling the published APK
```

Impact: A Firebase API key and production database URL are hardcoded directly in the binary, present in every installed copy of the APK and extractable by anyone who decompiles it (both values withheld from this public report; full values were disclosed privately to About You in the original R1 letter). This creates a quota and billing exhaustion attack surface against the underlying Google Cloud project and exposes the production database to unauthorized access if its security rules are not locked to authenticated, deny-by-default access. For an app serving 11 million-plus active customers, this is a direct violation of the technical-measures requirement of Art. 32 and the data-protection-by-design principle of Art. 25.

H1: Adjust and Facebook SDK initialize before consent, transferring fashion purchase-conversion data to Meta and Adjust in the US

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.2 — marketing attribution and conversion tracking begin before any consent interaction

```
com.adjust.sdk.AdjustReferrerReceiver -- android:exported="true"
com.facebook.internal.FacebookInitProvider -- ContentProvider, auto-init before
    consent
com/facebook/appevents -- conversion-event tracking to Meta Platforms (US)
```

Impact: com.adjust.sdk.AdjustReferrerReceiver is declared with android:exported=”true ”, making it addressable from outside the app, and measures marketing attribution and installation events. com.facebook.internal.FacebookInitProvider auto-initializes as a ContentProvider before any consent screen and transfers purchase-conversion events to Meta Platforms (US). On a fashion app processing style preferences, clothing sizes and purchase history, these conversion events let Meta build cross-app targeting profiles before the user has made any consent choice, with no Art. 44-49 transfer mechanism identified in the app’s available privacy information.

H2: Datadog RUM ContentProvider captures session analytics before consent, transferred to US infrastructure

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.0 — granular behavioural recording begins before the user has made any choice

```
com.datadog.android.rum.DdRumContentProvider -- ContentProvider, auto-init before
    consent
Captures: tap patterns, scroll depth, navigation paths, load times
Destination: Datadog Inc., San Francisco, CA, USA
```

Impact: com.datadog.android.rum.DdRumContentProvider auto-initializes as a ContentProvider before any consent screen and records granular session analytics, including tap patterns, scroll depth, navigation paths and load times. This behavioural recording begins before the user has actively used the app or made any consent decision. Datadog Inc. is based in San Francisco, California, constituting a transfer to the US with no Art. 44-49 mechanism identified in the app's available privacy information.

H3: Firebase initializes before consent, alongside a Braze CRM key present in app resources

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.5 — core infrastructure plus a full CRM-automation platform's key sitting pre-consent in the binary

```
com.google.firebase.provider.FirebaseInitProvider -- initOrder=100, pre-consent
com_braze_api_key: present in string resources [value withheld in this public report]
```

Impact: com.google.firebase.provider.FirebaseInitProvider initializes with initOrder=100, before any consent screen. A Braze API key is present in the app's string resources; Braze is a full CRM marketing-automation platform (push messaging, behavioural analytics, subscriber segmentation). If actively wired into the app's data flow, a fashion app with 11 million-plus active customers combining Braze CRM processing with purchase-behaviour and style-preference data would warrant a documented Art. 35 DPIA for that specific combination.

Impact Analysis

All four findings are routine, fixable engineering and consent-architecture gaps, not evidence of a company with no disclosure process. What distinguishes this case is the correspondence: 58 days of complete silence, then two replies, both pointing RFI-IRFOS toward a private, unpublished bug-bounty program instead of engaging with findings that had already been sitting in the company's own inbox, and were already public on RFI-IRFOS's own permanent ledger, for nearly two months. A redirect to a different intake channel is not an answer to a specific technical question, and RFI-IRFOS's own written objection to that redirect, sent the same day as the first reply, went unaddressed in the second.

The Complete Chain: Seven Messages, 109 Days, Two Replies, Zero Answers

Step 1 – Disclosure sent: RFI-IRFOS sends the full findings on 30 June 2026 to datenschutz@aboutyou.de (bounces immediately) and security@aboutyou.de (delivered), CC presse@aboutyou.de, the Austrian Datenschutzbehoerde, and the EDPS, stating an embargo of 28 September 2026.

Step 2 – Extended silence: Follow-ups on 17 July and 15 August 2026 restate the findings and the three questions. No reply to either, 58 days of silence.

Step 3 – First reply, a platform redirect: On 27 August 2026, security@aboutyou.com invites RFI-IRFOS to open a HackerOne account and resubmit through the private bug-bounty program.

Step 4 – Redirect rejected in writing: RFI-IRFOS replies the same day, explaining that the findings are already in About You's inbox and already public on RFI-IRFOS's ledger, naming the redirect as Pattern P-01 of its own published Corporate Response Pattern Atlas, and restating all three questions in English.

Step 5 – Second reply, same redirect repeated: Also on 27 August 2026, security@aboutyou.com cites About You's security.txt and repeats the HackerOne invitation, without addressing RFI-IRFOS's objection or any of the three questions.

Step 6 – Further follow-ups: RFI-IRFOS sends a follow-up on 28 August 2026 and a final message on 12 September 2026, naming the redirect as rejected and the three questions as unanswered after 74 days.

Step 7 – Embargo passes unanswered: 28 September 2026, the stated embargo date, passes with no further reply of any kind.

Step 8 – Publication: This report publishes 19 days after the embargo, with the full record intact: seven messages sent, two replies received, both redirecting to a different channel rather than answering, and all three questions still unanswered.

Data Protection – Article by Article

Art. 32(1)(b), Art. 25 GDPR – Security of processing, data protection by design: C1's hard-coded Firebase key and production database URL fall short of the technical measures these provisions require.

Art. 7, Art. 6(1) GDPR – Conditions for consent, lawfulness of processing: H1's pre-consent Adjust and Facebook SDK initialization begins marketing attribution and conversion tracking before any consent interaction.

Art. 44-49 GDPR – Transfers to third countries: H1's Meta/Adjust transfer and H2's Datadog transfer to the US have no documented mechanism identified in the app's available privacy information.

Art. 7 GDPR – Conditions for consent: H2's Datadog RUM session-analytics capture and H3's Firebase initialization both begin before any consent screen.

Regulatory & Legal Landscape

The Austrian Datenschutzbehoerde and the EDPS were in CC on the original disclosure and throughout the correspondence. About You GmbH & Co. KG operates under the Otto Group umbrella, headquartered in Hamburg, Germany.

Fine exposure under GDPR: Art. 83(4) applies to the Art. 32 and Art. 25 issue in C1, up to EUR 10,000,000 or 2% of total worldwide annual turnover. Art. 83(5) applies to the Art. 7, Art. 6(1), and Art. 44-49 issues in H1, H2, and H3, up to EUR 20,000,000 or 4% of total worldwide annual turnover. A company that redirects a disclosure already in its own inbox toward a private, unpublished bounty channel, rather than answering the specific questions raised, is itself a fact a supervisory authority may find relevant when assessing how seriously the underlying findings were handled internally.

Indicators of Compromise

The following findings were extracted from the production APK via static analysis only. No About You servers, accounts, or infrastructure were probed. The hardcoded key and database URL referenced in C1, and the Braze key referenced in H3, are withheld from this public report; full values were disclosed privately to About You in the original R1 letter.

```
C1 -- Hardcoded Firebase API key + production database URL,
  redacted in this public report

H1-H3 -- Adjust/Facebook, Datadog RUM, Firebase/Braze,
  all initializing before consent, transferring to US infrastructure
```

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure sent to datenschutz@aboutyou.de (bounced) and security@aboutyou.de (delivered), CC presse@aboutyou.de, Austrian Datenschutzbehoerde, EDPS. Embargo stated as 2026-09-28.

2026-07-17 Follow-up sent. No reply.

2026-08-15 Follow-up sent. No reply.

2026-08-27 (09:05) security@aboutyou.com replies for the first time: invites RFI-IRFOS to open a HackerOne account and resubmit through About You's private bug-bounty program.

2026-08-27 (09:20) RFI-IRFOS replies the same day: rejects the redirect, names it as Pattern P-01 of its own Corporate Response Pattern Atlas, restates the three questions in English.

2026-08-27 (11:45) security@aboutyou.com replies again: cites About You's security.txt and repeats the HackerOne invitation, does not address the objection or the three questions.

2026-08-27 (12:09) RFI-IRFOS replies again, same day, reiterating that coordinated disclosure, not a private bounty program, is the model in effect, and that an answer to the three questions is all that is required.

2026-08-28 Further follow-up sent. No reply.

2026-09-12 Final follow-up sent, naming the redirect as rejected and the three questions as unanswered after 74 days. No further reply.

2026-09-28 Main embargo date reached and passed with all three questions still unanswered.

2026-10-17 This report published, 19 days after the embargo date. Correspondence record: seven RFI-IRFOS messages, two replies received, both a platform redirect, zero of three questions answered.

Residual Risk & Recommendations

C1 – Immediate: rotate the hardcoded Firebase API key, remove the production database URL from the binary, and restrict database access rules server-side.

H1 – Immediate: gate Adjust and the Facebook SDK behind the app's consent flow, and document an Art. 44-49 safeguard for the resulting transfer to Meta and Adjust in the US.

H2 – Immediate: gate Datadog RUM initialization behind the app's consent flow, and document an Art. 44-49 safeguard for the transfer to Datadog's US infrastructure.

H3 – Document whether Braze is actively wired into the data flow and, if so, complete an Art. 35 DPIA for the combination of fashion purchase-behaviour data and CRM processing; gate Firebase initialization behind consent.

Procedural: redirecting a disclosure already received, and already public, toward a private bug-bounty intake does not resolve any of the four findings above. RFI-IRFOS remains open to a substantive answer to the three questions on record, in this same thread, at any time; this report will be updated to reflect one if it arrives.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No About You servers, accounts, or infrastructure were probed. The hardcoded credential, database URL, and Braze key referenced in findings C1 and H3 are withheld from this public report; full values were disclosed privately to About You in the original R1 letter and remain available to About You or to a supervisory authority on request. Technical evidence is archived under chain of custody. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF ABOUTYOU-2026-R1-001.